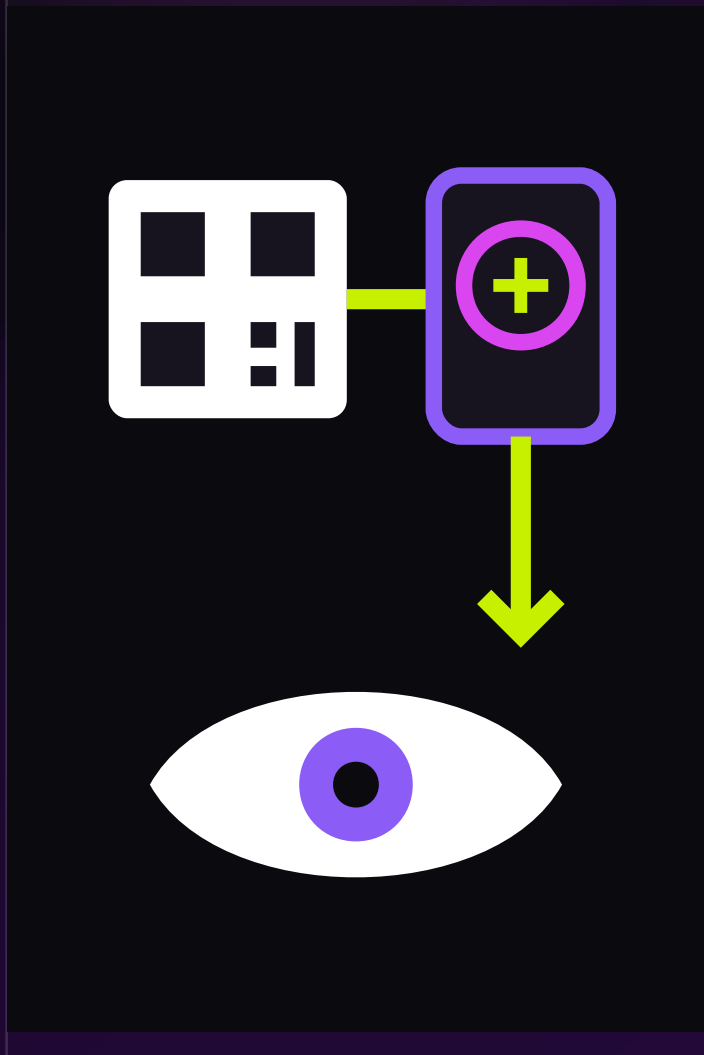
# UAT-11985 GOOGLE AITM

Hunts five source-published hostnames in email and QR-code-extracted URLs.

HUNTING QUERY

CONFIDENCE: MEDIUM



**REPORT DATE**
09 October 2026

**STATUS**
Untested implementation sketch

**PRIMARY PLATFORM**
Microsoft Defender XDR

**OPERATIONAL VALUE**
7.0 / 10

# EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

7.0

Hunts five source-published hostnames in email and QR-code-extracted URLs.

CLASSIFICATION

**Hunting query**

Medium confidence. Source-supported campaign evidence; environmental prevalence is not validated.

**1** primary table
**1** primary query
**0** production claims
**4** validation gates

**Evidence boundary**

A URL match does not prove delivery, QR scanning, credential capture, MFA bypass, or account compromise.

# BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

| # | Source-supported fact |
|---|---|
| 1 | Cisco Talos reported a spearphishing campaign targeting Taiwan-based research organizations. |
| 2 | The actor hid destinations behind benign-looking links and modified QR codes in event posters. |
| 3 | The published hostnames support retrospective campaign scoping only. |

### Detection hypothesis

If the published behavior occurs in a covered endpoint or cloud workload, EmailUrlInfo should retain the campaign-specific evidence used by this hunt.

### Unconfirmed elements

A URL match does not prove delivery, QR scanning, credential capture, MFA bypass, or account compromise.

**ATT&CK:** T1566.002

# TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

## EmailUrlInfo

Microsoft Defender XDR advanced hunting coverage must retain the fields referenced by the query.

OPTIONAL ENRICHMENT

Identity, device, network, file reputation, prevalence, owner, change record, and adjacent-event context.

| Requirement | Decision |
| --- | --- |
| Primary platform | Microsoft Defender XDR |
| Primary table | EmailUrlInfo |
| Query status | Untested implementation sketch |
| Classification | Hunting; no alerting before validation |

### Coverage caveat

An empty result may mean no match, missing telemetry, retention gaps, parser differences, or field sparsity.

# PRIMARY KQL

Source-supported conditions with investigable output.

HUNTING

STATUS

Hunting query — Untested implementation sketch

KQL — UNTESTED

```
// UAT-11985 Google AitM infrastructure in email and QR-code URLs
// Platform: Microsoft Defender XDR Advanced Hunting
// Status: Hunting query - Untested implementation sketch
// Confidence: Medium (source-confirmed IOC match; IOC expiry and tenant testing required)
// Prerequisite: Microsoft Defender for Office 365 populating EmailUrlInfo
// Evidence: Cisco Talos, 2026-10-08; IOCs published in Cisco-Talos/IOCs.
// Interpretation: A result is an IOC association, not proof of credential theft,
// MFA bypass, account takeover, campaign attribution, or successful delivery.
let UAT11985Domains = dynamic([
    "google.morelessty.com",
    "jmlh.morelessty.com",
    "google.centerhoti.com",
    "google.natrlyi.com",
    "accounts.natrlyi.com"
]);
EmailUrlInfo
| where UrlDomain in~ (UAT11985Domains)
| project Timestamp, NetworkMessageId, Url, UrlDomain, UrlLocation,
          UrlChainId, UrlChainPosition, ReportId
| order by Timestamp desc
```

# TRIAGE AND TUNING

Human validation before response.

WORKFLOW

**1**

## Preserve

Retain the raw event, device or account, timestamps, and campaign-matched values.

**2**

## Confirm

Validate field semantics and determine whether the matched object exists.

**3**

## Enrich

Add reputation, prevalence, owner, identity, network, and adjacent-event context.

**4**

## Scope

Search for related execution, persistence, access, and follow-on activity.

### Expected benign overlap

Administration, software development, security testing, automation, content inspection, shared infrastructure, or legitimate files may overlap. Tune only after ownership and prevalence are established.

### Response boundary

A URL match does not prove delivery, QR scanning, credential capture, MFA bypass, or account compromise.

# VALIDATION GATES

Controlled tests and promotion criteria.

QUALITY CONTROL

## Validation steps

1. Confirm the primary table and every projected field exist.
2. Replay an authorized benign event matching the query shape.
3. Measure at least 30 days of tenant prevalence and benign overlap.
4. Verify every result retains sufficient evidence for triage.

## Decision criteria

**Success:** the test is visible and real matches remain attributable.

**Rejection:** benign activity dominates or the campaign artifact is no longer reliable.

**Failure:** required telemetry or fields are unavailable.

### Promotion gate

Do not promote to production until telemetry, prevalence, ownership, and false-positive handling are demonstrated in the target environment.

# CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

### Hunting query

Hunts five source-published hostnames in email and QR-code-extracted URLs.

A URL match does not prove delivery, QR scanning, credential capture, MFA bypass, or account compromise.

## MITRE ATT&CK

T1566.002

## References

1. UAT-11985 primary technical research
2. Cisco Talos. "UAT-11985: AI-assisted event lures delivering real-time Google AitM phishing."
3. Publication date: 2026-10-08. Observed activity: mid-2026.
4. hxxps://blog[.]talosintelligence[.]com/uat-11985/
5. Source-maintained IOC list
6. Cisco Talos IOCs repository. uat-11985.txt. Accessed 2026-10-09.
7. hxxps://github[.]com/Cisco-Talos/IOCs/blob/main/2026/10/uat-11985.txt
8. Official schema documentation
9. Microsoft Learn. EmailUrlInfo advanced hunting table. Accessed 2026-10-09.
10. hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-emailurlinfo-table
11. ATT&CK mapping
12. MITRE ATT&CK T1566.002 - Phishing: Spearphishing Link.

### Document control

Canonical locked typography and layout. Only the campaign illustration on page 1 is variable.